

Androidアプリ セキュリティ検証コマンド集

目次

1. エクスポートされたコンポーネントの確認
 2. パーMISSIONの確認
 3. ディープリンクの確認
 4. ディープリンク脆弱性テスト
 5. データ漏洩チェック
 6. ネットワークセキュリティ
-

1. エクスポートされたコンポーネントの確認

実行コマンド

```
adb shell dumpsys package com.enoconan.testingappv2 | grep -A 5 "exported=true"
```

☑ 望ましい結果

```
Activity:
  MainActivity exported=true # ランチャーActivityのみ

# または出力なし（最小限のexported）
```

✗ よろしくない結果

```
Activity:
  AdminActivity exported=true
  SettingsActivity exported=true
  DebugActivity exported=true

Receiver:
  SensitiveDataReceiver exported=true

Service:
  BackupService exported=true
  DatabaseService exported=true
```

問題点: 内部用のコンポーネントが外部から呼び出し可能になっている

2. パーMISSIONの確認

実行コマンド

```
adb shell dumpsys package com.enoconan.testingappv2 | grep permission
```

☒ 望ましい結果

```
requested permissions:
  android.permission.INTERNET
  android.permission.POST_NOTIFICATIONS
  android.permission.USE_BIOMETRIC
  android.permission.VIBRATE
  android.permission.WAKE_LOCK
```

ポイント: アプリの機能に必要なパーミッションのみ

☒ よろしくない結果

```
requested permissions:
  android.permission.READ_CONTACTS      # 不要なのに連絡先
  android.permission.READ_SMS           # 不要なのにSMS
  android.permission.CAMERA             # 不要なのにカメラ
  android.permission.RECORD_AUDIO       # 不要なのにマイク
  android.permission.ACCESS_FINE_LOCATION # 不要なのに位置情報
  android.permission.READ_EXTERNAL_STORAGE
  android.permission.WRITE_EXTERNAL_STORAGE
```

問題点: アプリの機能に不要なパーミッションを要求している

3. ディープリンクの確認

実行コマンド

```
# Intent-filterの詳細確認
adb shell dumpsys package com.enoconan.testingappv2 | grep -B 5 -A 10 "intent-
filter"

# スキーム・ホスト・パスの確認
adb shell dumpsys package com.enoconan.testingappv2 | grep -B 3 -A 15 "scheme"
```

☒ 望ましい結果

```
intent-filter:
  Action: "android.intent.action.VIEW"
  Category: "android.intent.category.DEFAULT"
  Category: "android.intent.category.BROWSABLE"
  Scheme: "https"
  Host: "yourdomain.com"
  Path: "/register"
  AutoVerify: true
```

ポイント:

- HTTPSスキームを使用
- ホストが特定されている
- AutoVerifyが有効

✗ よろしくない結果

```
intent-filter:
  Scheme: "http"           # HTTPは盗聴可能
  Host: "*"                # すべてのホストを受け入れ
  Path: ".*"              # すべてのパスを受け入れ
  AutoVerify: false       # 検証なし
```

問題点:

- HTTPは暗号化されていない
- ワイルドカード使用で制限が緩い
- ドメイン検証がない

4. ディープリンク脆弱性テスト

4.1 基本的なディープリンクテスト

```
# アプリを完全終了してからテスト
adb shell am force-stop com.enoconan.testingappv2

# カスタムスキームでの起動テスト
adb shell am start -a android.intent.action.VIEW -d "testingapp://test"
```

☑ 望ましい結果

```
Starting: Intent { act=android.intent.action.VIEW dat=testingapp://test/... }
# アプリが起動し、ホーム画面または適切な画面が表示される
```

✕ よろしくない結果

```
Error: Activity class does not exist
# または
Starting: Intent { ... }
# アプリがクラッシュする
```

4.2 管理者機能へのアクセス試行

```
# 各テストの前にアプリを終了
adb shell am force-stop com.enoconan.testingappv2

# Admin画面へのアクセス試行
adb shell am start -a android.intent.action.VIEW -d "testingapp://admin"

# Settings画面へのアクセス試行
adb shell am start -a android.intent.action.VIEW -d "testingapp://settings"

# Debug画面へのアクセス試行
adb shell am start -a android.intent.action.VIEW -d "testingapp://debug"
```

☑ 望ましい結果

```
# Logcatで確認
adb logcat | grep -E "Invalid URI|Unsupported path"

# 出力例:
Unsupported path: /admin, redirecting to home
# アプリ画面: ホーム画面またはログイン画面が表示される
```

✕ よろしくない結果

```
# アプリ画面: 管理画面が直接開く (認証なし)
# または特別なエラーなくadmin機能にアクセスできる
```

問題点: 認証なしで管理機能にアクセス可能

4.3 認証バイパス試行

```
adb shell am force-stop com.enoconan.testingappv2
```

```
# 認証バイパス試行 (その1)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://login?bypass=true"

# 認証バイパス試行 (その2)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://auth?token=fake&admin=true"

# 認証バイパス試行 (その3)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://home?authenticated=1"
```

☒ 望ましい結果

```
# Logcatで確認
adb logcat | grep -E "Invalid|Unauthorized"

# パラメータが無視される、またはログイン画面へリダイレクト
```

☒ よろしくない結果

```
# アプリ画面: ログイン画面をスキップして認証済み状態になる
```

問題点: パラメータで認証をバイパス可能

4.4 データ操作試行

```
adb shell am force-stop com.enoconan.testingappv2

# 金額を負の値にする
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://payment?amount=-100"

# 金額を0にする
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://order?price=0"

# 異常に大きな値
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://payment?amount=999999999"
```

☒ 望ましい結果

```
# Logcatで確認
adb logcat | grep -E "Invalid amount|Invalid parameter"

# 出力例:
Invalid amount: -100
# アプリ画面: エラーメッセージまたはホーム画面
```

✗ よろしくない結果

```
# アプリ画面: 負の金額や0円での決済画面が表示される
# または異常な金額が処理される
```

問題点: 入力値の検証が不十分

4.5 SQLインジェクション試行

```
adb shell am force-stop com.enoconan.testingappv2

# SQLインジェクション試行 (その1)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://search?q=test' OR '1'='1"

# SQLインジェクション試行 (その2)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://user?id=1 UNION SELECT * FROM users--"

# SQLインジェクション試行 (その3)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://item?id=1'; DROP TABLE products;--"
```

☑ 望ましい結果

```
# Logcatで確認
adb logcat | grep -E "Invalid|Sanitized"

# 出力例:
Invalid ID format
# アプリ画面: エラーメッセージまたは何も表示されない
```

✗ よろしくない結果

```
# Logcatで確認
adb logcat | grep -i "sql"

# 出力例:
SQLiteException: near "OR": syntax error
# アプリ画面: SQLエラーが表示される、またはクラッシュ
```

問題点: SQLインジェクションが可能（データベース攻撃のリスク）

4.6 XSS (Cross-Site Scripting) 試行

```
adb shell am force-stop com.enoconan.testingappv2

# XSS試行 (その1)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://web?url=javascript:alert(1)"

# XSS試行 (その2)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://message?text=<script>alert(document.cookie)</script>"

# XSS試行 (その3)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://comment?content=<img src=x onerror=alert(1)>"
```

☒ 望ましい結果

```
# Logcatで確認
adb logcat | grep -E "Invalid URL|Blocked"

# JavaScriptスキームがブロックされる
# HTMLタグがエスケープされる
# アプリ画面: 通常のテキストとして表示される
```

☐ よろしくない結果

```
# アプリ画面: JavaScriptが実行される
# またはHTMLが解釈される
```

問題点: XSS攻撃が可能（WebView使用時に危険）

4.7 パストラバーサル試行

```
adb shell am force-stop com.enoconan.testingappv2

# パストラバーサル試行 (その1)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://file?path=../../etc/passwd"

# パストラバーサル試行 (その2)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://download?file=../../../../../data/data/"

# パストラバーサル試行 (その3)
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://image?src=../../../../../system/build.prop"
```

☑ 望ましい結果

```
# Logcatで確認
adb logcat | grep -E "Invalid path|Access denied"

# 出力例:
Invalid path: ../../etc/passwd
# アプリ画面: エラーメッセージまたは何も表示されない
```

✗ よろしくない結果

```
# アプリ画面: システムファイルの内容が表示される
# または任意のディレクトリにアクセス可能
```

問題点: ファイルシステムへの不正アクセスが可能

4.8 トークン検証テスト

```
adb shell am force-stop com.enoconan.testingappv2

# 正常なトークン
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://register?token=validToken123456"

# トークンなし
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://register"

# 短すぎるトークン
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://register?token=abc"
```



```
# 特殊文字を含むトークン
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://register?token=test<script>alert(1)</script>"

# 長すぎるトークン
adb shell am start -a android.intent.action.VIEW \
  -d "testingapp://register?
token=aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
"
```

☑ 望ましい結果

```
# 正常なトークン → 登録画面が開く
# トークンなし → エラー画面が開く
# 短すぎる/特殊文字/長すぎる → エラー画面が開く

# Logcatで確認
adb logcat | grep -E "Invalid token|Token is empty"
```

✗ よろしくない結果

```
# すべてのトークンで登録画面が開く
# または特殊文字が処理されずにそのまま使用される
```

問題点: トークン検証が不十分

5. データ漏洩チェック

5.1 Logcatでの機密情報漏洩確認

```
# アプリを操作しながらリアルタイムでログを監視
adb logcat | grep -iE
"password|token|secret|api_key|credit|card|email|phone|address"
```

☑ 望ましい結果

```
# 機密情報に関するログが出力されない
# または
[DEBUG] Login attempt for user: ***** (マスキングされている)
[INFO] Token validation: [REDACTED]
```

✗ よろしくない結果

```
[DEBUG] User password: mypassword123
[INFO] API Key: sk_live_51HxYZabcdef123456789
[DEBUG] Credit card: 4111-1111-1111-1111
[INFO] Email: user@example.com, Phone: 090-1234-5678
```

問題点: 機密情報がログに平文で出力されている

5.2 ローカルストレージの確認

```
# アプリのデータディレクトリを確認
adb shell run-as com.enoconan.testingappv2 ls -la
/data/data/com.enoconan.testingappv2/

# SharedPreferencesの確認
adb shell run-as com.enoconan.testingappv2 cat
/data/data/com.enoconan.testingappv2/shared_prefs/*.xml

# データベースの確認
adb shell run-as com.enoconan.testingappv2 ls -la
/data/data/com.enoconan.testingappv2/databases/
```

☑ 望ましい結果

```
<!-- SharedPreferences -->
<map>
  <string name="user_id">abc123</string>
  <string name="session_token">encrypted_data_here</string>
  <!-- パスワードやクレジットカード情報が保存されていない -->
</map>
```

ポイント:

- 機密情報が暗号化されている
- パスワードが保存されていない
- クレジットカード情報が保存されていない

✗ よろしくない結果

```
<!-- SharedPreferences -->
<map>
  <string name="password">mypassword123</string>
  <string name="credit_card">4111111111111111</string>
```

```
<string name="api_key">sk_live_51HxYZ...</string>
</map>
```

問題点: 機密情報が平文で保存されている

5.3 外部ストレージの確認

```
# 外部ストレージにアプリデータがないか確認
adb shell ls -la /sdcard/Android/data/com.enoconan.testingappv2/

# ダウンロードフォルダの確認
adb shell ls -la /sdcard/Download/ | grep -i testingapp
```

☒ 望ましい結果

```
# 機密情報を含むファイルが存在しない
# または暗号化されたファイルのみ
```

☒ よろしくない結果

```
-rw-rw---- 1 u0_a123 sdcard_rw 1234 2025-01-15 12:00 user_data.json
-rw-rw---- 1 u0_a123 sdcard_rw 5678 2025-01-15 12:00 database_backup.db
```

問題点: 機密情報が誰でもアクセス可能な外部ストレージに保存されている

6. ネットワークセキュリティ

6.1 ネットワークセキュリティ設定の確認

```
# ネットワーク設定の確認
adb shell dumpsys package com.enoconan.testingappv2 | grep -iA 5 "network"
```

☒ 望ましい結果

```
networkSecurityConfig: res/xml/network_security_config.xml
# またはデフォルトのセキュアな設定
```

☒ よろしくない結果

```
usesCleartextTraffic: true # HTTP通信を許可
```

問題点: 暗号化されていないHTTP通信が許可されている

6.2 通信内容の確認（中間者攻撃テスト）

```
# デバイスにプロキシを設定してから
# Burp SuiteやCharles ProxyなどのツールでHTTPS通信を傍受

# SSLピンニングが実装されているか確認
# 不正な証明書で通信が失敗するか確認
```

☑ 望ましい結果

```
# 不正な証明書を使用した場合
Connection failed: SSL handshake failed
Certificate verification failed
```

✗ よろしくない結果

```
# 不正な証明書でも通信が成功する
200 OK
# 中間者攻撃が可能
```

問題点: SSL/TLS証明書の検証が不十分

7. 総合テストスクリプト

すべてのテストを一括実行するスクリプト:

```
#!/bin/bash

PACKAGE="com.enoconan.testingappv2"
SCHEME="testingapp"

echo "=== Android Security Test Suite ==="
echo ""

# 1. Exported Components Check
echo "1. Checking exported components..."
adb shell dumpsys package $PACKAGE | grep -A 5 "exported=true"
```

```
echo ""

# 2. Permissions Check
echo "2. Checking permissions..."
adb shell dumpsys package $PACKAGE | grep "requested permissions:" -A 20
echo ""

# 3. Deep Link Tests
echo "3. Testing deep links..."

tests=(
    "$SCHEME://admin"
    "$SCHEME://settings"
    "$SCHEME://login?bypass=true"
    "$SCHEME://payment?amount=-100"
    "$SCHEME://search?q=test' OR '1'='1"
    "$SCHEME://file?path=../../etc/passwd"
    "$SCHEME://register"
    "$SCHEME://register?token=abc"
)

for url in "${tests[@]}; do
    echo "Testing: $url"
    adb shell am force-stop $PACKAGE
    sleep 1
    adb shell am start -a android.intent.action.VIEW -d "$url"
    sleep 2
    echo ""
done

# 4. Logcat Security Check
echo "4. Checking for sensitive data in logs..."
echo "Monitoring for 10 seconds..."
timeout 10 adb logcat | grep -iE "password|token|secret|api_key|credit" &
sleep 10
echo ""

echo "=== Test Complete ==="
```

使用方法

```
# スクリプトを保存
nano security_test.sh

# 実行権限を付与
chmod +x security_test.sh

# 実行
./security_test.sh
```

まとめ

このドキュメントのテストを実行することで、以下のセキュリティリスクを検証できます:

- ☒ 不正なコンポーネントアクセス
- ☒ 過剰なパーミッション要求
- ☒ ディープリンクの脆弱性
- ☒ 認証バイパス
- ☒ データ操作攻撃
- ☒ SQLインジェクション
- ☒ XSS攻撃
- ☒ パストラバーサル
- ☒ データ漏洩
- ☒ ネットワークセキュリティ

各テストで「望ましい結果」になることを確認し、「よろしくない結果」が出た場合は該当箇所の修正を行ってください。